

Änderungsprotokoll — Adressverwaltung v2.4.0

Datum: 9. Oktober 2026

Ausgangsstand: v2.3.0 (Commit 8f976b6)

Endstand: Commits 68d2789, dc6f6e4, 594258d, 3484396 und der Commit mit der Fassung dieses Dokuments, die Abschnitt 4 enthält

Versionsnummer: 2.4.0 (vorher 2.3.0)

1. Übersicht

Version 2.4.0 fasst die Änderungen vom 9. Oktober 2026 zusammen. Die Abschnitte 2 und 3 standen zuerst als Nachträge im Änderungsprotokoll der Version 2.3.0 und sind von dort hierher verschoben.

#	Paket	Inhalt	Commit
1	Zweite Sicherheitsprüfung	11 Befunde (S-19 bis S-29), alle behoben	68d2789, dc6f6e4
2	Offene Punkte	O-03 bis O-08 aus dem Sicherheitsbericht bearbeitet	594258d
3	Einstellungen	Fehler beim Ändern der E-Mail-Adresse behoben; Farbe der Oberfläche wählbar	nach 3484396
4	Dokumentation	Diagramme, Schulungsunterlage und Tutorial auf den Stand des Codes gebracht	3484396
5	Aufräumen	Überholte Dokumente und Dateien gelöscht	3484396
6	Version	Versionsnummer auf 2.4.0 gesetzt	3484396

Das Datenbankschema ändert sich: Die Tabelle `Users` erhält die Spalten `Role` und `TokenVersion`, die Tabelle `Settings` die Spalte `AccentColor`. Das Backend ergänzt sie beim Start selbst; bestehende Daten bleiben erhalten.

Für den Betrieb ändert sich einiges; Abschnitt 3 beschreibt unter «Nach dem Aktualisieren zu tun», was nötig ist.

2. Zweite Sicherheitsprüfung

Eine zweite Prüfung ergab 11 weitere Befunde (S-19 bis S-29): 7 mittlere und 4 niedrige. Alle sind behoben (Commit 68d2789, 19 Dateien, davon 4 neu). Das Datenbankschema ändert sich dadurch nicht. Befunde und Begründungen stehen in `documentation/Sicherheitsbericht.pdf`, Abschnitt 3.2.

Backend

Datei	Änderung
<code>Controllers/ODataCrudController.cs</code>	POST verwirft eine mitgeschickte <code>id</code> ; PATCH ignoriert sie (vorher Fehler 500)
<code>Data/AdresseDbContext.cs</code>	<code>ChangeDate</code> und <code>ChangedBy</code> werden beim Anlegen geleert und lassen sich nicht mehr vorbelegen
neu <code>ODataErrorDetailFilter.cs</code>	OData-Fehlerantworten ohne Ausnahmetyp und Stacktrace

Datei	Änderung
neu Services/ILoginThrottle.cs, Services/MemoryLoginThrottle.cs	Kontosperre: nach 5 Fehlversuchen ist die E-Mail-Adresse 15 Minuten gesperrt
Controllers/AuthController.cs	Login prüft und führt die Kontosperre (Antwort 429); [AllowAnonymous] auf dem Login
Program.cs	Fallback-Policy: jeder Endpunkt verlangt ein Token, auch /odata und /odata/\$metadata; nur HS256; Cache-Control: no-store; kein Server-Header

Frontend

Datei	Änderung
lib/auth.ts	Anmeldungen ohne Backend-Token werden abgelehnt (betrifft die Google-Anmeldung)
middleware.ts	Seiten nur mit einer Session, die ein Backend-Token enthält
app/login/LoginForm.tsx	Hinweis, wenn NextAuth eine Anmeldung abgelehnt hat
next.config.mjs	Kein X-Powered-By
Dockerfile	Node.js 22 statt Node.js 20 (ohne Sicherheitsupdates seit 30. April 2026)

Infrastruktur und Skripte

Datei	Änderung
nginx/nginx.conf	TLS 1.2 nur noch mit ECDHE und AES-GCM oder ChaCha20; CSP um default-src 'self' und Quellen für Skripte, Styles, Bilder und Verbindungen ergänzt
docker-compose.yml	Backend und Frontend mit no-new-privileges und ohne Linux-Capabilities
scripts/reset_password.sh	Mindestlänge 8 gilt auch für ein als Argument übergebenes Passwort
scripts/create_user.sh	E-Mail-Adresse in Kleinbuchstaben; Prüfung auf bestehende Adresse ohne Rücksicht auf die Schreibweise

Tests und Dokumentation

Datei	Änderung
neu AdressverwaltungApi.Tests/HardeningTests.cs	6 Tests: Over-Posting, PATCH mit id, Fehlerdetails, no-store, Kontosperre und Zurücksetzen des Zählers
AdressverwaltungApi.Tests/AuthorizationTests.cs	3 weitere Fälle: /odata, /odata/\$metadata und /settings ohne Token
documentation/Sicherheitsbericht.html und .pdf	um die zweite Prüfung ergänzt (S-19 bis S-29, O-08)
CLAUDE.md	an die Änderungen angepasst

Nach dem Aktualisieren zu tun

1. **Images neu bauen und nginx neu starten.** docker compose up --build -d, danach docker compose restart nginx. Bestehende Sitzungen bleiben gültig.
2. **Kontosperre.** Nach 5 falschen Passwörtern ist eine E-Mail-Adresse 15 Minuten gesperrt. Ein Neustart des Backends hebt die Sperre auf.

3. **Metadaten mit Token.** Werkzeuge wie Postman brauchen für `/odata/$metadata` jetzt den `Authorization-Header`.
4. **Fremde Quellen.** Eine Schrift, ein Skript, ein Bild oder eine API von einem fremden Ursprung braucht einen Eintrag in der CSP in `nginx/nginx.conf`.
5. **Google-Anmeldung.** Sie wird abgelehnt, bis das Backend für eine Google-Identität ein Token ausstellen kann.

Auf dem Entwicklungsrechner ist Punkt 1 bereits erledigt.

Prüfung

Prüfung	Ergebnis
<code>dotnet test</code>	60 von 60 bestanden (9 neu)
<code>dotnet list package --vulnerable --include-transitive</code>	keine anfälligen Pakete
<code>npm audit --omit=dev</code>	0 Lücken
Frontend-Build mit Node.js 22, Typprüfung und Lint im Docker-Image	erfolgreich
Docker-Stack per <code>curl</code> : Anmeldung, Startseite, Städteliste, Einstellungen	erfolgreich
Endpunkte ohne Token, Fehlerantwort ohne Stacktrace, Kontosperrung, TLS-Verfahren, Header, Container-Einstellungen	wie beabsichtigt

Nicht im Browser geprüft: ob die neue CSP im Browser etwas blockiert, und der Hinweis des Login-Formulars bei einer abgelehnten Anmeldung. Die Google-Anmeldung liess sich nicht prüfen, weil sie nicht konfiguriert ist.

3. Offene Punkte der Sicherheitsprüfung behoben

Die offenen Punkte O-03 bis O-08 aus dem Sicherheitsbericht sind bearbeitet: fünf behoben, O-07 verkleinert.

Das Datenbankschema ändert sich: Die Tabelle `users` erhält die Spalten `Role` und `TokenVersion`; das Backend ergänzt sie beim Start selbst. Einzelheiten stehen in `documentation/Sicherheitsbericht.pdf`, Abschnitt 3.3.

Punkt	Änderung
O-03 Seitengrösse	Höchstens 100 Zeilen pro Antwort; Listen im Frontend blättern mit 25 Zeilen, Städteliste mit Suche
O-04 Token im Browser	API-Aufrufe des Browsers über den Proxy <code>/api/backend</code> ; kein Token mehr in der Session; CSP mit Nonce
O-05 Rollen	Admin und User; Benutzer anlegen und Einstellungen ändern nur als Admin
O-06 Widerruf	Token-Version pro Benutzer; Abmeldung und Passwort-Reset machen ausgestellte Tokens ungültig
O-07 Entwicklungswerkzeuge	Tailwind CSS 4; <code>npm audit</code> meldet 5 statt 9 Einträge
O-08 Datenbank-Superuser	Backend verbindet sich mit der Rolle <code>adressverwaltung_app</code>

Backend

Datei	Änderung
<code>Models/User.cs</code> , neu <code>Models/Roles.cs</code>	Felder <code>Role</code> und <code>TokenVersion</code> ; Rollen Admin und User

Datei	Änderung
neu SchemaUpgrader.cs	Ergänzt die neuen Spalten in einer bestehenden Datenbank; vorhandene Benutzer werden Admin
neu TokenUserValidator.cs	Prüft bei jeder Anfrage Benutzer und Token-Version und übernimmt die Rolle aus der Datenbank
Services/JwtTokenService.cs	Token enthält die Token-Version (tv)
Controllers/AuthController.cs, Dtos/AuthDtos.cs	Registrierung nur als Admin, optional mit Rolle; neu POST /auth/logout; Login liefert die Rolle
Controllers/SettingsController.cs	PUT /settings nur als Admin
Controllers/ODataCrudController.cs	Seitengröße 100 für Listen
Data/AdresseDbContext.cs, DbSeeder.cs, Program.cs, appsettings.json	Standardwerte der neuen Spalten; Seed-Benutzer ist Admin; Einbindung von Validator und Schema-Nachzug; Datenbankbenutzer

Frontend

Datei	Änderung
neu app/api/backend/[...pfad]/route.ts, lib/apiHeader.ts	Proxy zum Backend, hängt das Token serverseitig an; Schutz vor Cross-Site-Request-Forgery
lib/api.ts	Browser ruft den Proxy auf; Blättern (getAdressenSeite, getCitiesSeite); bei 401 zurück zum Login
lib/auth.ts, types/next-auth.d.ts	Session ohne Token, dafür mit Rolle; serverAuthOptions für Server Components; Abmeldung ruft /auth/logout auf
middleware.ts, app/layout.tsx	Seitenschutz ohne Umweg über /api/auth/signin; CSP mit Nonce pro Antwort
app/page.tsx, app/cities/page.tsx, neu components/Seitenwahl.tsx	Blättern in beiden Listen; Suche in der Städteliste; Aktionsspalte bricht nicht mehr um
app/einstellungen/page.tsx	Formular für die Rolle User gesperrt
app/globals.css, postcss.config.mjs, package.json; gelöscht tailwind.config.ts	Tailwind CSS 4; Klassennamen in 9 Dateien angepasst (shadow → shadow-sm usw.)

Infrastruktur und Skripte

Datei	Änderung
neu db/init/10-app-rolle.sh, scripts/create_db_role.sh	Legt die Datenbankrolle des Backends an (neue bzw. bestehende Datenbank)
docker-compose.yml, .env.example	Neues Geheimnis APP_DB_PASSWORD; Backend verbindet sich als adressverwaltung_app
nginx/nginx.conf	Feste CSP nur noch für Antworten ohne eigene CSP (API, statische Dateien, Fehlerseiten)
scripts/create_user.sh	Viertes Argument für die Rolle (Standard User)
scripts/reset_password.sh	Widerruft die Tokens des Benutzers

Tests und Dokumentation

Datei	Änderung
neu AdressverwaltungApi.Tests/RolesAndRevocationTests.cs	9 Tests: Rechte der Rollen, Rollenwechsel, Abmeldung, gelöschter Benutzer, Seitengrösse
AdressverwaltungApi.Tests/Infrastructure/ApiFactory.cs	Testbenutzer ist Admin; weitere Benutzer mit wählbarer Rolle
documentation/Sicherheitsbericht.html und .pdf, README.md, CLAUDE.md	nachgeführt

Nach dem Aktualisieren zu tun

1. **Neues Geheimnis.** APP_DB_PASSWORD in .env eintragen (openssl rand -hex 24).
2. **Datenbankrolle bei bestehender Datenbank.** docker compose up -d db, dann ./scripts/create_db_role.sh. Bei einer neuen Datenbank entfällt das.
3. **Images neu bauen.** docker compose up --build -d, danach docker compose restart nginx.
4. **Rollen prüfen.** Vorhandene Benutzer sind Admin. Wer nur Adressen pflegen soll, wird in der Datenbank auf User gesetzt; neue Benutzer erhalten User.
5. **Lokale Entwicklung.** Im Frontend npm ci ausführen (Tailwind CSS 4). dotnet run verbindet sich als adressverwaltung_app mit APP_DB_PASSWORD (siehe README).

Auf dem Entwicklungsrechner sind die Punkte 1 bis 3 bereits erledigt.

Prüfung

Prüfung	Ergebnis
dotnet test	69 von 69 bestanden (9 neu)
dotnet list package --vulnerable --include-transitive	keine anfälligen Pakete
npm audit --omit=dev	0 Lücken (mit Entwicklungswerkzeugen: 5)
Frontend-Build mit Typprüfung und Lint im Docker-Image	erfolgreich
Browser (Chromium, ferngesteuert): Anmeldung, alle Seiten, Anlegen, Ändern, Löschen, Suchen, Blättern, Abmelden	erfolgreich, keine Fehler und keine CSP-Verstösse in der Konsole
Token im Browser, eingeschleuster Inline-Handler, Proxy ohne Header, altes Cookie nach Abmeldung, Rolle User	kein Token; blockiert; 403; 401; Einstellungen gesperrt
Oberfläche vor und nach Tailwind CSS 4 (Bildschirmfotos)	gleiches Aussehen

Nicht geprüft: andere Browser als Chromium, die Bedienung von Hand und die Google-Anmeldung (nicht konfiguriert).

4. Einstellungen

Fehler: E-Mail-Adresse liess sich nicht mehr ändern

Seit der Einführung der Rollen sperrte die Einstellungsseite das Formular, wenn die Session des Benutzers keine Rolle Admin enthielt. Die Rolle in der Session stammt aber vom Login. Wer schon vor der Aktualisierung angemeldet war, hatte eine Session ohne Rolle: Das Feld war gesperrt, obwohl der Benutzer in der Datenbank Admin ist und das Backend das Speichern erlaubt hätte. Dasselbe wäre nach jedem Rollenwechsel passiert.

Jetzt meldet das Backend mit den Einstellungen, ob der Benutzer ändern darf (`canEdit`). Es liest die Rolle dafür bei jeder Anfrage aus der Datenbank. Eine erneute Anmeldung ist nicht nötig.

Dabei behoben: Eine leere E-Mail-Adresse wurde mit Fehler 400 abgelehnt, obwohl die Seite «Leer lassen = keine E-Mail-Benachrichtigungen» verspricht. Leer ist jetzt erlaubt.

Neu: Farbe der Oberfläche

Auf der Einstellungsseite lässt sich die Farbe von Kopfzeile, Schaltflächen und Links wählen: Blau (Standard), Grün, Türkis, Violett, Rot, Orange oder Grau. Die Farbe gilt für alle Benutzer; ändern darf sie nur die Rolle Admin. Die Login-Seite bleibt blau, weil die Einstellungen ohne Anmeldung nicht lesbar sind.

Datei	Änderung
Models/Settings.cs, neu Models/AccentColors.cs	Feld <code>AccentColor</code> ; Liste der erlaubten Farben. Die E-Mail-Adresse darf leer sein
Dtos/SettingsDtos.cs	Anfrage mit optionaler Farbe; Antwort mit <code>accentColor</code> und <code>canEdit</code>
Controllers/SettingsController.cs	Prüft E-Mail-Adresse und Farbe selbst (400 bei ungültigen Werten); liefert <code>canEdit</code>
Data/AdresseDbContext.cs, SchemaUpgrader.cs	Spalte <code>Settings.AccentColor</code> mit Standardwert <code>blue</code> ; wird in einer bestehenden Datenbank ergänzt
frontend/app/globals.css	Palette akzent aus CSS-Variablen; ein Block pro Farbe
neu frontend/lib/farben.ts, frontend/lib/api.ts	Liste der Farben; <code>getAkzentfarbe</code> , Einstellungen mit Farbe und <code>canEdit</code>
frontend/app/layout.tsx	Setzt die gewählte Farbe als <code>data-farbe</code> am <code><html></code> -Element
frontend/app/einstellungen/page.tsx	Farbwahl; Sperre nach <code>canEdit</code> statt nach der Rolle in der Session
Seiten und Komponenten mit Farbklassen	<code>blue-...</code> durch <code>akzent-...</code> ersetzt
neu AdressverwaltungApi.Tests/SettingsTests.cs	8 Tests: Standardwerte, <code>canEdit</code> je Rolle, Speichern von E-Mail und Farbe, leere E-Mail, ungültige Werte

Nach dem Aktualisieren: `docker compose up --build -d`, danach `docker compose restart nginx`. Die neue Spalte entsteht beim Start des Backends.

Prüfung	Ergebnis
<code>dotnet test</code>	77 von 77 bestanden (8 neu)
Frontend-Build mit Typprüfung und Lint im Docker-Image	erfolgreich
Browser (Chromium, ferngesteuert) als Admin: E-Mail-Feld frei, E-Mail und Farbe speichern, leere E-Mail speichern	erfolgreich; Kopfzeile wechselt ohne Neuladen die Farbe, keine Fehler in der Konsole
Browser als User	Formular gesperrt, gewählte Farbe sichtbar

Nicht geprüft: der Fall einer Session aus der Zeit vor den Rollen selbst (er liess sich nicht nachstellen; geprüft ist, dass die Seite die Rolle der Session nicht mehr verwendet), andere Browser als Chromium und der Kontrast jeder Farbe von Hand.

5. Dokumentation

Datei	Änderung
documentation/Sequenzdiagramm.puml und .svg	Proxy <code>/api/backend</code> , Kontosperrung, Rolle und Token-

Datei	Änderung
	Version, Abgleich mit der Datenbank, Abmeldung bei 401; 44 statt 38 Schritte
documentation/Systemarchitektur.puml und .svg	Proxy, CSP mit Nonce, TokenUserValidator, SchemaUpgrader, Rolle adressverwaltung_app, create_db_role.sh
documentation/ Schulungsunterlage_Sequenzdiagramm.html, .pdf und beide PNG	Neu erzeugt; erläutert die 44 Schritte
neu documentation/Tutorial_WebApp_v2.4.html und .pdf	Lehrmittel zum aktuellen Stand, einschliesslich Abschnitt 4; ersetzt die Ausgaben 2.0 und 2.1. Alle Codebeispiele stimmen wörtlich mit den Quelldateien überein
documentation/Sicherheitsbericht.html und .pdf	Versionsangabe
documentation/Aenderungsprotokoll_v2.3.0.md und .pdf	Nachträge vom 9. Oktober 2026 in dieses Dokument verschoben
README.md	Schrittzahl, Weg der API-Aufrufe über den Proxy, Versionstabelle, Verweis auf das Tutorial
CLAUDE.md	Version; Hinweis auf das Tutorial; überholte Angaben entfernt

Neu im Tutorial gegenüber der Ausgabe 2.1: Geheimnisse in .env, HTTPS mit nginx und mkcert, Tests, Rollen, Widerruf von Tokens, Kontosperre, Proxy für API-Aufrufe, Content-Security-Policy mit Nonce, Blättern in Listen, eigene Datenbankrolle, Schemaupgrader, Akzentfarbe. Vier Übungsaufgaben im Anhang C sind ersetzt, weil ihre Lösung inzwischen im Projekt steht.

6. Aufgeräumt

Datei	Grund
documentation/ Tutorial_WebApp_v2.0.pdf	Durch Tutorial_WebApp_v2.4 ersetzt
documentation/ Tutorial_WebApp_v2.1.html, Tutorial_WebApp_v2.1.pdf	Durch Tutorial_WebApp_v2.4 ersetzt
documentation/Tutorial_WebApp_v2.1-1.pdf	Kopie von Tutorial_WebApp_v2.1.pdf (Byte für Byte gleich)
documentation/ Aenderungsprotokoll_v2.2.0-1.pdf	Kopie von Aenderungsprotokoll_v2.2.0.pdf (Byte für Byte gleich)
backend/api-tests.http	Stammte aus der Zeit vor der Anmeldung: kein Token, Eigenschaften in PascalCase – jede Anfrage schlug fehl. Aufrufe mit Token zeigt das Tutorial im Anhang B
documentation/github.odt, documentation/github_ssh.odt	Persönliche Notizen; aus dem Repository genommen und in .gitignore eingetragen. Die Dateien selbst bleiben auf dem Rechner

Die Änderungsprotokolle der früheren Versionen und die Versionsbündel unter archive/ bleiben als Nachweis der Entwicklung erhalten. Gelöschte Dateien lassen sich aus der Git-History zurückholen.

7. Versionsnummer

Die Version 2.4.0 steht in `README.md`, `CLAUDE.md`, `frontend/package.json`, `frontend/package-lock.json`, in beiden Diagrammen, in der Schulungsunterlage, im Sicherheitsbericht und im Tutorial.

Restrisiken und akzeptierte Punkte stehen in `documentation/Sicherheitsbericht.pdf`, Abschnitt 4.